

외부 화면(iframe) ↔ Plex Admin ID Token 연동

HAW-1165 · 2026-09-21 개정 — 외부 파트너 명세 반영, adminfront/sample-dashboard 구현 완료

1차 제안 대비 변경점. 사용자 속성(이름·이메일 등)을 평문으로 그대로 넘기는 방식에서, 외부 파트너 요청대로 Keycloak이 서명한 ID Token(JWT)을 넘기고 그쪽에서 직접 검증하는 방식으로 바꿨습니다. 메시지 타입도 REQUEST_USER_INFO → id-token-request 로, 응답도 loading 단계가 추가된 2단계 구조로 바뀌었습니다.

1. 통신 방식

방향	메시지	내용
child → parent	id-token-request	토큰 요청 (payload 없음)
parent → child	id-token status= loading	refresh 시작 직후 즉시 발송
parent → child	id-token status= success	idToken (JWT) 포함
parent → child	id-token status= error	일시적 오류(네트워크/5xx), Plex 세션은 유효

2. 흐름

- child가 id-token-request 전송
- parent가 즉시 status=loading 응답 후, keycloak.updateToken(-1) 로 강제 재발급 시도
- 성공 — status=success + 새 idToken 전달 (매번 새 jti 보장)
- Plex 세션 자체가 끝난 경우(invalid_grant) — 메시지 대신 keycloak.login() 으로 전체 페이지 리다이렉트
- 일시적 오류(네트워크/5xx) — status=error 응답, child는 재시도 가능

3. ID Token 검증 (외부 서버 쪽에서 수행)

parent는 서명된 토큰만 건네고, 신뢰 여부 판단은 외부 서버가 직접 합니다:

- kid 로 Keycloak JWKS 조회 → RS256 서명 검증
- iss , exp 확인
- aud / azp 가 plex_front 인지 확인
- typ 이 ID 인지 확인(Bearer 토큰과 구분)
- jti 재사용(replay) 거부

4. parent 쪽 보안·안정성 처리

- 요청 검증: event.source 가 그 iframe 자신인지 → event.origin 이 그 iframe이 embed 중인 origin인지, 두 단계로 확인
- 응답은 검증된 origin으로만 전송('*' 브로드캐스트 금지)
- 요청 스팸 방지 — 5초 이내 재요청은 무시(throttle)

5. 구현 상태

bb8-plex-adminfront (parent, ExternalFramePage.vue)와 sample-dashboard (child 데모)에 위 프로토콜을 반영했고, 양쪽 빌드 확인을 마쳤습니다. 데모 페이지는 서명 검증 없이 수신한 토큰을 디코딩해서 보여주는 것까지만 확인합니다(서명 검증은 백엔드가 있는 실제 외부 서버 몫). 실제 브라우저 통합 테스트는 sandbox 배포 후 진행 예정입니다.